MULTI-CLOUD FDE STACK #02

MULTI-CLOUD FDE STACK · ISSUE 02 OF 08

Identity is the first integration.

IAM, Cloud IAM and Entra ID, without a single static key.

02

AR

Akhilesh Ranjan Singh

Senior DevSecOps Engineer · github.com/iarsingh

Swipe →

Pods without keys

CLOUD	MECHANISM
AWS EKS	EKS Pod Identity or IRSA
GCP GKE	Workload Identity Federation
Azure AKS	Entra Workload ID
CI/CD	GitHub OIDC federation

AR
Akhilesh Ranjan Singh
github.com/iarsingh

Users: OAuth2, OIDC and JWT

01 **OIDC for sign-in**

Use the customer identity provider. Never build your own login.

02 **Validate every JWT**

Signature, issuer, audience and expiry, on every request.

03 **Short-lived tokens**

Minutes for access tokens, refresh through the provider.

04 **Authorisation in your code**

Map groups to roles, then check the resource itself.

AR
Akhilesh Ranjan Singh
github.com/iarsingh

RBAC done right

COMMON

- One admin role for the service
- Role checks only in the UI
- Shared service account
- Keys in a .env file

BETTER

- Roles per job to be done
- Checks in the API layer
- One identity per workload
- Federated, short-lived credentials

AR
Akhilesh Ranjan Singh
github.com/iarsingh

INTERVIEW SCENARIO

“We cannot give you a service account key.”

Good. Ask for workload identity instead: no key to leak, rotate or explain at audit.

AR
Akhilesh Ranjan Singh
github.com/iarsingh

Identity checklist

- [x] SSO through their identity provider
- [x] JWT validation tested with bad tokens
- [x] One cloud identity per workload
- [x] Least-privilege roles, reviewed
- [x] No long-lived keys anywhere

AR
Akhilesh Ranjan Singh
github.com/iarsingh

KEY TAKEAWAY

If a credential can be copied, assume it will be.

→ Federate pods and pipelines

→ Validate JWTs fully, every time

→ Authorise on the resource, not the screen

YOUR TURN

How long did your last project wait for cloud access?

FOLLOW AKHILESH RANJAN SINGH

Next in the series: #03 VPC, firewall rules, VNet

Save · Repost

AR
Akhilesh Ranjan Singh
github.com/iarsingh